ZetaERP — Manual Bug-Testing SOP

Part 3 — Settings (Company, GST, Sequences, Users, Roles & Access)

Document	QA-SOP-03 — Settings
Product	ZetaERP / Zenith (multi-tenant POS / ERP)
Environment under test	Production — https://erp.zetaclantech.com
Scope of this part	The admin **Settings** area: the four reachable screens — **Company Setup**, **Users**, **Roles**, **Edit Role / module access** — behind the admin gate. (GST/Sequences/Companies-list/Notifications/etc. were orphaned dead code and have been removed.)
Audience	Manual QA tester (admin access required)
Document owner	Platform / Solo-dev
Status	Active
Last updated	2026-07-01

CONTENTS

1. Purpose

2. Critical rules for the tester (read before starting)

3. Test environment & preconditions

4. Test data

5. Conventions & severity

6. Flow map

7. ACCESS GATE (permissions)

8. COMPANY SETUP

9. GST CONFIGURATION — (REMOVED — dead code, not testable)

10. DOCUMENT SEQUENCES — (REMOVED — dead code, not testable)

11. USERS & ROLE ASSIGNMENT

- 11.1 Create & manage users
- 11.2 Password policy & validation
- 11.3 Role assignment & isolation

12. ROLES & MODULE ACCESS

13. MULTI-TENANT ISOLATION (high priority)

14. UI / SECURITY

15. Cross-flow / regression & defect template

16. Areas to probe hardest (attention map)

17. Teardown (mandatory)

---

1. Purpose

This Standard Operating Procedure tells a tester **exactly how to manually test the Settings module end-to-end (A→Z)** — configuring the company, GST, document numbering, users, roles and module access — including the **edge cases**, the **multi-tenant isolation** cases, the **security/permission** cases, and the **visual/UI** cases, and **how to record a defect** when behaviour differs from the *Expected Result*.

Settings is **administrative** — its changes affect everyone in the organization (and some affect the whole platform). Test deliberately.

---

2. Critical rules for the tester (read before starting)

> ⚠️ **This is a LIVE commercial system. Settings changes are high-impact.**

1. **Never edit a real company's legal/tax data** on MARUTHI (org `100000`) or any live tenant. (The Document-Sequences screen — which could have renumbered live bills — has been removed; if it ever returns, the same rule applies: throwaway tenants only.)
2. **Never disable or lock out the only/last admin** of an organization — you can make the account unmanageable. Only disable **test** users you created.
3. **Never edit a real company's legal/tax data** (GSTIN, PAN, TAN, CIN, legal name, financial-year) on MARUTHI or any live tenant. Use a throwaway tenant, and **never fabricate** a tax number.
4. **Module-access / role changes can be platform-wide.** Roles (`ZENITH_*`) and their module access are shared security objects — editing one can affect **every tenant** using that role. Only the platform administrator should change these; as a tester, **observe**, don't re-wire live roles.
5. **Multi-tenant isolation is a key risk here** (see §13). If a tenant admin can see or edit **another tenant's** companies, sequences, GST or users, that is **Critical** — capture it immediately.
6. **Clean up every test user, role, and setting** you create (see §17), and confirm you left MARUTHI's settings exactly as they were.

---

3. Test environment & preconditions

The Settings area opens from the app menu → **Settings & Roles** and is **admin-gated** — only users in the `ZENITH_ADMIN` or `ADMIN` group can see it; everyone else gets an **"Access Restricted"** screen.

Screen	URL (`/apps/zenith/Settings/…`)
Company Setup — default	`…/Settings/CompanySetup`
Users & Role Assignment	`…/Settings/Users`
Roles & Access	`…/Settings/Roles`
Edit Role Access	`…/Settings/EditRole?userGroupId=<role>`

> **Note (2026-07-01):** the reachable Settings module is exactly these four screens behind the admin gate. Earlier drafts of this SOP listed GST Configuration, Document Sequences, a Companies list, Notifications, Company Groups, Backups, Access Control and Digital Signatures — those were **orphaned, unreachable screens** (mounted nowhere) and have been **removed as dead code**. The cases for them below are retained only as "removed / not applicable". If any of those features is wanted later, it should be built into this gated module deliberately.

Two admin tiers matter for testing:

- **Platform admin** (`ADMIN` group, e.g. john.doe) — sees all tenants; can create roles and edit module access.
- **Tenant admin** (`ZENITH_ADMIN`, e.g. a tenant's owner account) — manages their own org's users, but **should not** see other tenants' data.

Browsers: full pass on Desktop Chrome; spot-check Edge/Safari/mobile. **Tools:** DevTools (Console/Network), a second tenant login for isolation tests, a QA inbox.

---

4. Test data

Label	Use
`QA_USER_1`	A test user you create (username + password)
`QA_ROLE`	A test role `ZENITH_QATEST` (platform-admin tests only)
Throwaway tenant	A non-MARUTHI org for the high-risk Company/GST/Sequence tests
Valid password	Meets policy: ≥8 chars, ≥1 digit, ≥1 special (e.g. `Qa-test1!`)
Fake tax data	Clearly-fake PAN/GSTIN for the throwaway tenant only

---

5. Conventions & severity

Case Type: `FUNC` · `EDGE` · `UI` · `A11Y` · `SEC` · `PERF` · `ISO` (isolation) · `PERM` (permission gate).

Sev	Meaning	Example
S1 — Critical	Cross-tenant exposure/edit, bill-numbering corruption, admin lockout, permission bypass	Tenant A edits Tenant B's document sequence; a non-admin reaches Settings
S2 — High	Major setting broken / wrong	Company profile won't save; password reset fails; role can't be assigned
S3 — Medium	Wrong behaviour, limited impact	Weak password accepted; FY-start not honoured
S4 — Low	Cosmetic / minor UX	Misaligned table on mobile; tooltip typo

Logging a defect (template §15): Case ID, steps, expected vs actual, which admin tier/tenant you were, browser, screenshot, Console/Network capture.

---

6. Flow map

```
Settings (admin-gated: ZENITH_ADMIN or ADMIN) — four reachable screens
├─ Company Setup — own org only (name, country, currency, PAN/TAN/CIN, GSTIN, FY start, settings)
├─ Users ──────── create user · assign/remove role · reset password · disable/enable   (org-scoped)
└─ Roles ──────── create ZENITH_ role (platform admin) ──► Edit Role ── module access NONE/VIEW/FULL
(GST Config, Document Sequences, Companies list, Notifications, Company Groups, Backups,
 Access Control, Digital Signatures were orphaned dead code — removed.)
```

---

7. ACCESS GATE (permissions)

ID	Type	Title	Steps	Expected result	Sev
ST-001	PERM	Admin sees Settings	Log in as an admin, open Settings	The menu and screens render	S2
ST-002	PERM	Non-admin blocked	Log in as a **cashier/regular** user, open `…/Settings/Users` (and other Settings URLs directly)	**"Access Restricted"** — no settings content, no data leaked	S1
ST-003	PERM	Direct-URL bypass attempt	As a non-admin, hit each Settings sub-URL directly	Every one is gated; none render data	S1
ST-004	PERM	Create-user is admin-only	(Dev-assisted) POST the createUser transition as a non-admin	Rejected: "Only an administrator can change settings"	S1

---

8. COMPANY SETUP

Screen: `…/Settings/CompanySetup` (the default Settings screen; renders the admin's **own** organization). The separate "Companies list" screen was removed (orphaned).

ID	Type	Title	Steps	Expected result	Sev
ST-011	FUNC	Open company setup	Open Settings → Company Setup	Shows **your own** org: Org Code, Name, Country, Currency, PAN, TAN, CIN, GSTIN records, FY start, settings	S2
ST-012	FUNC	Edit company profile	On a **throwaway tenant**, change Name / PAN / TAN / CIN → Update	Persists after reload	S2
ST-013	FUNC	Financial-year start	Set FY Start month → Save	Persists; document numbering FY reflects it (e.g. `INV/26-27/…`)	S2

ID	Type	Title	Steps	Expected result	Sev
ST-014	FUNC	Company settings key/values	View the settings list; edit a value	Persists	S3
ST-015	EDGE	Bad PAN/TAN/CIN	Enter malformed values	**Record actual** — is format validated? (likely not server-side)	S3
ST-016	ISO	Cross-tenant company list	(The "Companies" list screen is an **orphaned/unreachable** screen — see §13 note)	n/a — not reachable via `/apps`, `/qapps`, or `/vapps`; defensively org-scoped anyway	S3
ST-017	ISO	Cross-tenant company setup	As tenant A's admin, open `CompanySetup?partyId=<Tenant-Borg id>`	**SAFE (verified):** the reachable Company Setup renders **your own** organization regardless of the `partyId` in the URL, and write actions are blocked ("Cannot modify another organization") unless you're the platform admin	S1

---

9. GST CONFIGURATION — *(REMOVED — dead code, not testable)*

> **This screen was an orphaned, unreachable duplicate and has been deleted.** GST is configured per-tenant at signup/onboarding and on the contact/company records. The cases below are retained for historical reference only.

Screen (removed): `…/Settings/GstConfiguration`. Registered GSTINs, GST slabs, composition/e-invoice flags, a test calculator.

ID	Type	Title	Steps	Expected result	Sev
ST-020	FUNC	GST page renders	Open GST Configuration	Registered GSTINs, GST slabs (rate/CGST/SGST), composition & e-invoice flags	S2
ST-021	FUNC	Test GST calc	Use the test calculator with an amount + rate	Returns correct CGST/SGST (intra-state) or IGST (inter-state) split	S2
ST-022	FUNC	Update GST config	On a throwaway tenant, toggle composition / e-invoice → Save	Persists	S3
ST-023	ISO	⚠ Cross-tenant GSTINs	As a tenant admin, view the registered-GSTIN list	**Record actual.** If GSTINs of **other tenants** show, that's a **Critical** leak (the legal GSTIN of another business)	S1

---

10. DOCUMENT SEQUENCES — *(REMOVED — dead code, not testable)*

> **This screen was orphaned and unreachable and has been deleted.** Document numbering is currently handled by the system, not an editable admin screen — which is the safer state (no UI exists to renumber issued bills). The cases below are retained for reference, and as the **acceptance criteria** if a numbering screen is ever (re)built: it must be admin-gated, org-scoped, and must prevent setting "Next Number" below the highest issued value.

Screen (removed): `…/Settings/Sequences`. Prefix, suffix, next number, pad length, include-FY.

ID	Type	Title	Steps	Expected result	Sev
ST-030	FUNC	Sequence list	Open Document Sequences	Lists document types with prefix/suffix/next/pad/include-FY	S2
ST-031	FUNC	Change prefix (throwaway)	On a throwaway tenant, set a new prefix → Update; create a document	New document uses the new prefix + FY format	S2
ST-032	EDGE	Next-number guards	Set "Next Number" **below** the highest already-issued number	**Record actual.** It should be **prevented or warned** — otherwise the next document **duplicates an existing number** (S1 integrity). Test on throwaway only	S1

ID	Type	Title	Steps	Expected result	Sev
ST-033	EDGE	Pad length / non-numeric	Set pad length to a letter, or next-number to text	Rejected cleanly, no 500	S3
ST-034	ISO	Cross-tenant sequences	(The Document Sequences screen is **orphaned/unreachable** — see §13 note)	n/a — not reachable via `/apps`, `/qapps`, or `/vapps` (the Vue app returns "Screen not found"); defensively org-scoped + write-guarded anyway. **The reachable Settings surface does not expose document sequences.**	S2
ST-035	FUNC	FY rollover	With include-FY on, check the FY portion	Correct FY (e.g. 26-27) per the company's FY-start month	S3

---

11. USERS & ROLE ASSIGNMENT

Screen: `…/Settings/Users`. Create users, assign/remove roles, reset passwords, enable/disable. The list is **org-scoped** for tenant admins (platform admin sees everyone).

11.1 Create & manage users

ID	Type	Title	Steps	Expected result	Sev
ST-040	FUNC	User list scope	Open Users as a **tenant admin**	Shows only **your organization's** users (platform admin sees all)	S1
ST-041	FUNC	Create user	Create New User → username, full name, password (twice)	User created, scoped to your tenant, given a default active organization	S2
ST-042	FUNC	New user can log in	Log in as the new user (with its Org ID)	Reaches the app, sees only this tenant's data	S2
ST-043	FUNC	Disable user	Disable a **test** user	Their login is blocked; their past records remain intact	S2
ST-044	FUNC	Enable user	Re-enable the test user	Login works again	S3
ST-045	FUNC	Reset password	Reset a test user's password (twice)	New password works; old one doesn't	S2

11.2 Password policy & validation

ID	Type	Title	Data	Expected result	Sev
ST-050	FUNC	Password mismatch	Password ≠ Verify	Rejected with a clear message	S3
ST-051	FUNC	Weak password	`abc`, `abcdefgh`, `12345678`	Rejected — policy is **≥8 chars, ≥1 number, ≥1 special char** (same as login)	S3
ST-052	FUNC	Strong password	`Qa-test1!`	Accepted	S3
ST-053	EDGE	Duplicate username	Create a user with an existing username	Rejected (usernames are unique)	S3
ST-054	EDGE	Empty fields	Submit blank username/password	Rejected, no 500	S3

11.3 Role assignment & isolation

ID	Type	Title	Steps	Expected result	Sev
ST-060	FUNC	Assign role	+ Role → pick a role (e.g. ZENITH_CASHIER) → Assign	Role badge appears on the user; their access changes accordingly	S2
ST-061	FUNC	Remove role	Click ✕ on a role	Role removed	S3

ID	Type	Title	Steps	Expected result	Sev
ST-062	FUNC	Only Zenith roles	(Dev-assisted) try to assign a non-`ZENITH_` group	Rejected: "Only Zenith roles can be assigned"	S2
ST-063	ISO	Can't manage another tenant's user	As Tenant A admin, try to assign/reset/disable a **Tenant B** user (by id)	**Blocked** — the action checks the user is in your active org (`check#UserInActiveOrg`). Confirm it refuses	S1
ST-064	SEC	Can't self-escalate cross-tenant	As a tenant admin, try to add yourself/your user to a platform role	Should not grant platform-admin powers; capture actual	S1

12. ROLES & MODULE ACCESS

Screens: `…/Settings/Roles`, `…/Settings/EditRole?userGroupId=`.

ID	Type	Title	Steps	Expected result	Sev
ST-070	FUNC	Roles list	Open Roles	Lists `ZENITH_*` roles with user count + module count	S2
ST-071	PERM	Create role is platform-admin only	As a **tenant admin**, try Create Role	Rejected/hidden — only the platform `ADMIN` can create roles	S1
ST-072	FUNC	Create role (platform admin)	Role ID `ZENITH_QATEST`, description → Create	Created and listed	S3
ST-073	EDGE	Role ID must start `ZENITH_`	Create a role id `QATEST`	Rejected: "Role ID must start with ZENITH_…"	S3
ST-074	FUNC	Edit module access	Open a role → set modules to No Access / View Only / Full Access → Save All Access	Persists; users with that role get exactly that access	S2
ST-075	PERM	Module access is platform-admin only	As a **tenant admin**, open Edit Role	**Read-only** — the Save button is hidden and a "managed by the platform administrator" notice shows	S1
ST-076	SEC	Module-access change is global	(Platform admin) change a shared role's access	**Be careful:** this affects **every tenant** using that role — verify the blast radius is understood, not a surprise	S2
ST-077	FUNC	View vs Full enforcement	Give a role View Only on a module, log in as a member	They can open but not add/edit/delete in that module	S2

13. MULTI-TENANT ISOLATION (high priority)

ID	Type	Title	Steps	Expected result	Sev
ISO-001	ISO	Users org-scoped	Tenant A admin sees only Tenant A users	Confirmed (the list filters by tenant group)	S1
ISO-002	ISO	Company Setup is own-org only	Tenant A admin opens Company Setup (any partyId)	**SAFE (verified):** always renders Tenant A's own org; cross-org writes blocked	S1
ISO-003	ISO	Users org-scoped	Tenant A admin opens Users	Only Tenant A's users (platform admin sees all)	S1
ISO-004	ISO	User actions cross-tenant	Tenant A admin tries to reset/disable a Tenant B user	Blocked (`check#UserInActiveOrg`)	S1
ISO-005	ISO	Role creation/access global	Tenant admin cannot create roles or change module access	Blocked (platform-admin only)	S1
ISO-006	ISO	Orphaned config screens	Try to reach Companies / Document Sequences / GST Configuration as any user	**Not reachable** (the Vue app returns "Screen not found"); they're dead code, defensively hardened. Confirm they remain unreachable	S3

> **Tester note (resolved):** an investigation confirmed the *reachable* Settings surface — **Company Setup, Users, Roles, Edit Role** — is correctly isolated (Company Setup renders own-org only and blocks cross-org writes; Users is org-scoped with `check#UserInActiveOrg`

> on every action; Roles/Edit-Role are platform-admin-only). The previously-suspected leaks (Companies list, Document Sequences, GST Configuration) live in **orphaned, unreachable screens** and were additionally org-scoped + gated defensively in case they are ever re-mounted.

---

14. UI / SECURITY

> **Notifications, Company Groups, Backups, Access Control and Digital Signatures were orphaned/unreachable screens and have been removed.** (If wanted, build them into the gated module.) The remaining cases apply to the live screens (Company Setup, Users, Roles, Edit Role).

ID	Type	Title	Check	Expected result	Sev
ST-085	UI	Desktop layout	Live screens at 1920/1366	Tables aligned, no overflow	S4
ST-086	UI	Mobile layout	Settings at 360–390px	No horizontal scroll; dialogs fit	S3
ST-087	A11Y	Keyboard	Tab through create-user / role dialogs	Logical order, visible focus, Enter submits	S3
ST-088	SEC	XSS in free-text	Put `<img src=x onerror=alert(1)>` in a role description / company name	Stored/escaped as text, never executes	S1
ST-089	SEC	CSRF	(Dev-assisted) POST a settings transition without the session token	Rejected	S2

---

15. Cross-flow / regression & defect template

ID	Type	Title	Expected result	Sev
XF-001	FUNC	New user → role → login → access	Create user, give a role, log in: they see exactly what the role allows	S2
XF-002	FUNC	Disable hides everywhere	A disabled user can't log in anywhere	S2
XF-003	ISO	End-to-end isolation	Nothing a Tenant A admin changes is visible/editable by Tenant B (and vice-versa)	S1
XF-004	FUNC	Sequence change → next doc	(Throwaway) a prefix change shows on the very next created document	S2

```
Defect ID:        ZE-SETTINGS-____
Linked Case ID:   ST-0__ / ISO-0__ / XF-0__
Title / Severity / Type:
Environment:      Prod | <browser> | admin tier: platform ADMIN / tenant ZENITH_ADMIN | tenant:
Steps / Expected / Actual:
Evidence:         screenshot + Console/Network (mandatory for ISO/PERM/SEC)
Notes:            user/role/org ids touched — NEVER paste passwords
```

---

16. Areas to probe hardest (attention map)

1. **Reachable isolation is verified** (§13) — Company Setup own-org-only, Users org-scoped, Roles/Edit-Role platform-admin-only. Re-confirm these after any change; they're the live isolation surface.
2. **Document Sequences** — when a numbering screen *is* exposed (it currently isn't reachable), editing "Next Number" on a live tenant is a **bill-number integrity** risk; keep it admin-gated, org-scoped, and never touch live data.
3. **Permission gates (§7, ST-071/075)** — non-admins fully blocked; tenant admins can't create roles or change module access.
4. **Password policy (ST-051)** — user create/reset must enforce ≥8/1-digit/1-special.
5. **Admin lockout** — never disable the last admin; confirm there's a safeguard or at least document the risk.

---

17. Teardown (mandatory)

1. **List and remove every test user, role, and setting** you created (capture ids).
2. Confirm you **did not change any Document Sequence, GSTIN, or company profile on MARUTHI** (org `100000`) or any live tenant.
3. Confirm no real admin was left disabled.
4. Delete any downloaded backups/exports from the test machine.
5. Attach the run sheet(s) + defect ids to this part's report.

End of Part 3 — Settings. Related: Part 1 — Login & Onboarding; Part 2 — Contacts; Part 4 — POS Billing Terminal; Part 5 — Sales & Invoicing; Part 6 — Inventory. The flagged isolation gaps in Companies / Sequences / GST should be triaged with the dev before broad tenant testing.